

Informe NIST SP800-20.

NIST SP 800-20, en realidad, no es un marco de indicadores, sino un documento ya retirado sobre validación de modos de operación de Triple DES; el verdadero “marco de métricas” NIST moderno es SP 800-55 “Measurement Guide for Information Security”, revisado y ampliado precisamente en 2024 como guía general para diseñar métricas e indicadores de ciberseguridad a nivel organizativo y, por extensión, nacional. A efectos prácticos, si España quisiera alinear indicadores nacionales con la familia SP 800, tendría que apoyarse en SP 800-55 (métricas), SP 800-30 (análisis de riesgo), SP 800-53 (controles) y SP 800-207 (Zero Trust), más el ecosistema europeo (NIS2, ENS, ENISA), no en el SP 800-20 ya obsoleto.¹²³⁴⁵⁶

1. Qué entiende hoy NIST por “indicadores”

Desde 2024 NIST ha consolidado SP 800-55 como una guía en dos volúmenes para crear programas de medición de seguridad, con un énfasis explícito en seleccionar métricas ligadas a objetivos de negocio, usar técnicas estadísticas básicas y modelar impacto y probabilidad. El volumen 1 se centra en cómo identificar y priorizar medidas, tanto cuantitativas como cualitativas, mientras que el volumen 2 recoge catálogos de medidas de referencia para áreas como gestión de vulnerabilidades, respuesta a incidentes, protección de datos o gestión de identidades.⁷⁸⁹

NIST insiste en que una “métrica” útil no es un número brillante en un dashboard, sino una medida claramente definida, repetible, con fórmula, fuente de datos, frecuencia de recogida y umbral de decisión, integrada en un programa con roles, gobierno y gestión de la calidad de los datos. En otras palabras: el indicador que no cambia una decisión de presupuesto, priorización o diseño arquitectónico es, filosóficamente hablando, ruido con pretensiones.¹⁰¹¹

1 <https://csrc.nist.gov/pubs/sp/800/20/upd2/final>

2 <https://csrc.nist.gov/publications/PubsSPs.html>

3 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

4 <https://www.slideshare.net/slideshow/the-national-security-framework-of-spain/264362024>

5 <https://www.ansi.org/standards-news/all-news/1-19-24-measuring-the-effectiveness-of-cybersecurity-in-companies-nist-publishes-guidance>

6 <https://csrc.nist.gov/news/2024/nist-releases-volumes-1-and-2-of-sp-800-55>

7 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

8 <https://content.govdelivery.com/accounts/USNIST/bulletins/3c50c39>

9 <https://csrc.nist.gov/news/2024/nist-releases-volumes-1-and-2-of-sp-800-55>

10 <https://content.govdelivery.com/accounts/USNIST/bulletins/3c50c39>

2. Tipología de métricas NIST y trasposición a nivel país

El renovado 800-55 distingue varias categorías funcionales de medidas (eficacia de controles, eficiencia, impacto, cumplimiento, madurez organizativa), y propone que el programa de medición siempre comience por los objetivos (“reducir incidentes significativos”, “mejorar tiempo de detección”, etc.) y no por los datos que “ya tenemos”. Adaptar esto a un nivel nacional exige el mismo ejercicio, pero con objetivos de política pública (resiliencia de servicios esenciales, reducción de cibercrimen, desarrollo de capacidades, etc.) en lugar de “SLA internos”.¹²¹³¹⁴

Para un marco estatal inspirado en NIST, las métricas se agrupan de forma bastante natural:

- Métricas de amenaza y exposición (volumen y tipo de incidentes, severidad, sectores afectados, técnicas predominantes).
- Métricas de capacidad y preparación (cobertura de ENS/NIS2, número y madurez de SOCs, adopción de Zero Trust, capacidades de respuesta y forense).
- Métricas de resultados e impacto (pérdidas económicas estimadas, interrupciones de servicios críticos, impactos reputacionales, litigios y sanciones).
- Métricas de desarrollo de capacidades y cultura (profesionales formados, ejercicios nacionales, campañas de concienciación, inversión pública y privada).³⁷⁶

NIST sugiere explícitamente usar técnicas de análisis estadístico simples y modelos de impacto/probabilidad para conectar estas medidas con decisiones de inversión y riesgo, lo que encaja bien con un enfoque “actuarial” aplicado a ciberresiliencia nacional.¹⁵¹⁶

3. España: indicadores nacionales recientes y su encaje NIST

España ha empezado a producir indicadores agregados a nivel país a través de varios instrumentos, que encajan bastante bien con las categorías NIST aunque no siempre lo digan en voz alta. El Plan Nacional de Ciberseguridad y, más recientemente, el refuerzo aprobado en 2025, cuantifican el problema: en 2024 se detectaron en España más de 100.000 ciberataques, con un incidente “muy grave” aproximadamente cada tres días, y una subida acumulada del 300 % en el número de ciberataques desde 2015.¹⁷

¹¹ <https://csrc.nist.gov/news/2024/nist-releases-volumes-1-and-2-of-sp-800-55>

¹² <https://csrc.nist.gov/news/2024/nist-releases-volumes-1-and-2-of-sp-800-55>

¹³ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

¹⁴ <https://content.govdelivery.com/accounts/USNIST/bulletins/3c50c39>

¹⁵ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

¹⁶ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

¹⁷ <https://www.ansi.org/standards-news/all-news/1-19-24-measuring-the-effectiveness-of-cybersecurity-in-companies-nist-publishes-guidance>

INCIBE, por su parte, informó en marzo de 2025 que su CERT gestionó 97.348 incidentes de ciberseguridad en 2024, con un aumento del 16,6 % respecto a 2023; de ellos, el 67,6 % afectaron a ciudadanía y el 32,4 % a empresas. De facto, estos números constituyen métricas de resultado (volumen de incidentes), segmentadas por tipo de víctima y evolución temporal, perfectamente alineables con un catálogo NIST 800-55 aunque se presenten en clave comunicativa más que de “medición de rendimiento”.¹⁸

En el ámbito normativo y de gobernanza, España ha actualizado el Esquema Nacional de Seguridad (ENS) y lo alinea con exigencias europeas; documentación oficial subraya que el ENS fija requisitos mínimos de seguridad para las administraciones públicas y promueve mecanismos de seguimiento del cumplimiento y la evolución de la madurez. Aunque la documentación pública no siempre detalla los indicadores, el propio diseño del ENS obliga a medir niveles de cumplimiento, número de sistemas certificados y tipo de deficiencias detectadas, lo que entra en la categoría de métricas de cumplimiento y madurez organizativa en la terminología NIST.^{19,20}

En paralelo, la transposición de NIS2 en España se articula mediante la futura Ley de Coordinación y Gobernanza de la Ciberseguridad, que crea el Centro Nacional de Ciberseguridad (CNCS) como autoridad única para supervisar operadores esenciales y servicios importantes, con poderes de auditoría, sanción y obligaciones de notificación de incidentes. El cronograma oficial prevé aprobación de la ley en el BOE en el primer trimestre de 2026 y puesta en marcha de un portal de registro e información de incidentes en el primer semestre de 2026, lo que sugiere que, a partir de ese momento, España dispondrá de series de datos sistemáticas sobre incidentes notificados que podrán alimentar un cuadro de mando nacional al estilo NIST.²¹

4. Comparativa mundial: hacia dónde van los indicadores

A nivel global, el Índice Global de Ciberseguridad de la UIT sigue siendo una referencia de medición comparativa entre países, midiendo cinco pilares: medidas legales, técnicas, organizativas, de desarrollo de capacidades y de cooperación. Aunque la última metodología conocida sigue en esta línea, la UIT ha reforzado la importancia de las medidas legales y la adopción de leyes de privacidad y ciberdelitos, constatando que ese pilar es, paradójicamente, donde más avanzado está el conjunto de países.²²

Frente a estos índices macro, el enfoque de NIST 800-55 es menos “ranking” y más “ingeniería de métricas”: interesa que cada país defina medidas que efectivamente guíen su política y asignación de

¹⁸ <https://www.slideshare.net/slideshow/the-national-security-framework-of-spain/264362024>

¹⁹ <https://www.ansi.org/standards-news/all-news/1-19-24-measuring-the-effectiveness-of-cybersecurity-in-companies-nist-publishes-guidance>

²⁰ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

²¹ <https://www.slideshare.net/slideshow/the-national-security-framework-of-spain/264362024>

²² <https://www.ansi.org/standards-news/all-news/1-19-24-measuring-the-effectiveness-of-cybersecurity-in-companies-nist-publishes-guidance>

recursos, no tanto que colecciona medallas comparativas. No obstante, nada impide —y de hecho es recomendable— usar los pilares de la UIT como dimensiones y rellenarlos con indicadores contruados siguiendo la metodología NIST: por ejemplo, bajo “medidas técnicas” medir porcentaje de operadores críticos con SOC 24/7, tiempo medio de detección de incidentes significativos, cobertura de MFA en servicios públicos, adopción de cifrado fuerte y, progresivamente, de criptografía poscuántica.²³²⁴²⁵²⁶²⁷

Un área emergente donde NIST está marcando tendencia, y que inevitablemente se trasladará a indicadores nacionales, es la migración a criptografía resistente a cuántica: la National Cybersecurity Center of Excellence ha publicado borradores de guías enfatizando que la migración llevará años, requiere inventarios criptográficos, pruebas de interoperabilidad y diseños híbridos, y que los nuevos algoritmos no serán reemplazos “drop-in” sino que traerán nuevos costes y complejidades. Esto se presta a métricas específicas: porcentaje de sistemas críticos inventariados, porcentaje migrado a esquemas híbridos, número de incidentes o fallos operativos ligados a la transición, etc., que un país puede incluir en su dashboard nacional si quiere tomarse en serio el riesgo cuántico.²⁸

5. Qué podría hacer España con este marco (y qué harían los “mejores CISOs del mundo”)

Si uno tomara el 800-55 como catecismo y lo aplicara a España, el guion sería algo así (en versión resumida y sin PowerPoints asesinos): primero, clarificar objetivos de política nacional en ciberseguridad (por sector, por tipo de amenaza, por impacto) y, a partir de ahí, formular preguntas de gestión: “¿estamos reduciendo los incidentes muy graves en operadores esenciales?”, “¿detectamos antes?”, “¿se recuperan los servicios críticos dentro de los RTO definidos?”. Solo después se seleccionan métricas, se normalizan definiciones entre INCIBE, CCN-CERT, CNCS, operadores críticos y otros actores, y se establece una gobernanza clara de los datos para evitar que cada organismo publique cifras incompatibles.²⁹³⁰³¹³²

23 <https://www.ansi.org/standards-news/all-news/1-19-24-measuring-the-effectiveness-of-cybersecurity-in-companies-nist-publishes-guidance>

24 <https://csrc.nist.gov/news/2024/nist-releases-volumes-1-and-2-of-sp-800-55>

25 <https://csrc.nist.gov/news/2024/nist-releases-volumes-1-and-2-of-sp-800-55>

26 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

27 <https://content.govdelivery.com/accounts/USNIST/bulletins/3c50c39>

28 <https://content.govdelivery.com/accounts/USNIST/bulletins/3c50c39>

29 <https://www.ansi.org/standards-news/all-news/1-19-24-measuring-the-effectiveness-of-cybersecurity-in-companies-nist-publishes-guidance>

30 <https://content.govdelivery.com/accounts/USNIST/bulletins/3c50c39>

31 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

En segundo lugar, la creación del CNCS ofrece una oportunidad para incrustar en la propia ley —al estilo NIS2 pero con ambición NIST— obligaciones de medición y reporte que vayan más allá del “incidente sí/no” y cubran tiempos, impactos, controles fallidos, cobertura de medidas y nivel de madurez; esto facilitaría, por ejemplo, emitir cada año un informe nacional de ciberresiliencia comparable al estilo de los informes de auditoría que promueve NIST para programas federales en Estados Unidos. Una selección razonable de indicadores podría incluir tasas de notificación por sector, distribución de técnicas de ataque, indicadores de Zero Trust (porcentaje de accesos con autenticación fuerte, segmentación efectiva, etc.) y métricas de capacidad humana (número de profesionales formados, rotación, brechas de talento).³³³⁴³⁵

Por último, la tendencia global apunta a incorporar explícitamente métricas de riesgo sistémico y de resiliencia, no solo de “ciberseguridad” en sentido defensivo estricto: interrupciones de servicios esenciales, impactos en cadenas de suministro, dependencia de proveedores únicos, y capacidad de continuidad de negocio tras incidentes significativos. España, con su combinación de ENS, NIS2, planes de ciberseguridad y un nuevo CNCS, está en posición de diseñar un sistema de indicadores que, si se construye siguiendo la disciplina metodológica de NIST 800-55 y se alimenta con las fuentes de datos ya existentes (INCIBE, CCN, operadores, cuerpos de seguridad), podría situarse en el grupo de países que no solo reaccionan al incidente de turno, sino que miden de forma sistemática la salud cibernética del país.³⁶³⁷³⁸

12131415

³² <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

³³ <https://www.incibe.es/incibe/sala-de-prensa/incibe-presenta-su-balance-de-ciberseguridad-2024-con-mas-de-97000-incidentes>

³⁴ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

³⁵ <https://content.govdelivery.com/accounts/USNIST/bulletins/3c50c39>

³⁶ <https://www.linkedin.com/pulse/itu-global-cybersecurity-index-2024-bassel-kablawi-sxt2f>

³⁷ <https://www.ansi.org/standards-news/all-news/1-19-24-measuring-the-effectiveness-of-cybersecurity-in-companies-nist-publishes-guidance>

³⁸ <https://thequantuminsider.com/2025/09/19/nist-cybersecurity-center-outlines-roadmap-for-secure-migration/>